

B3 - TP24 Portswigger "Username enumeration via different responses"

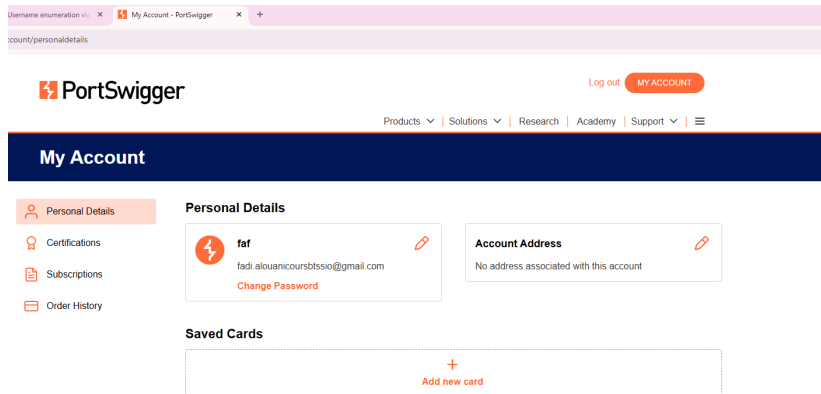
Sommaire

Introduction.....	1
1 Créer un compte sur https://portswigger.net/.....	3
2Télécharger puis installer BurpSuite community edition.....	3
https://portswigger.net/burp/releases#community	3
3 Faire l'exercice "Username enumeration via different responses".....	3
Lien :	
https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-different-responses	3
4 Rédiger le compte-rendu de votre travail avec les captures d'écran personnalisées.	
A placer dans le portfolio	3
Conclusion.....	4

Introduction

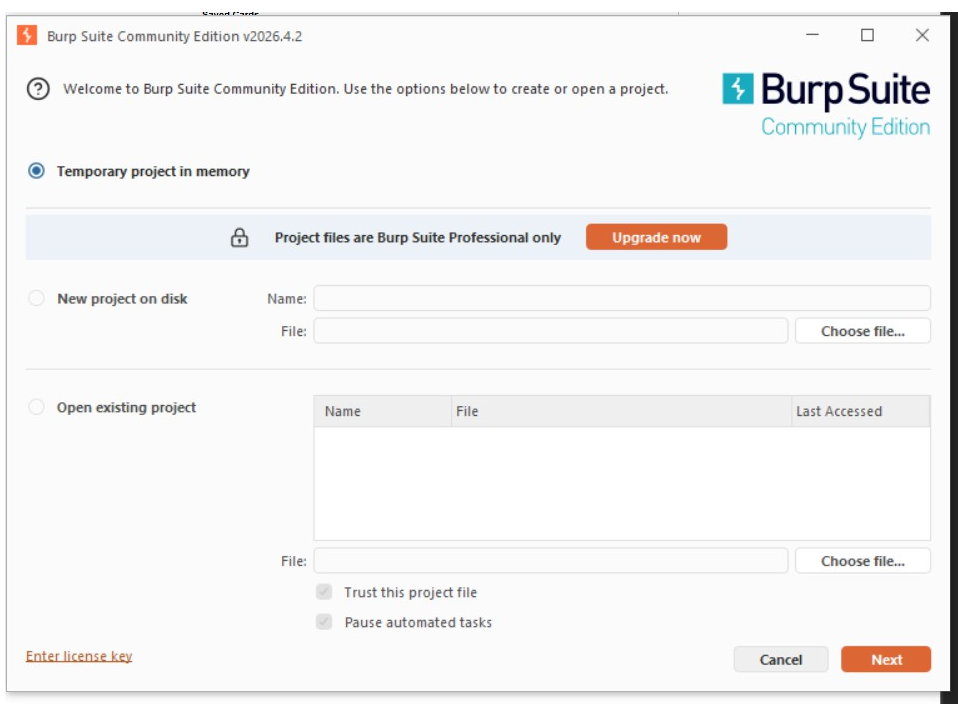
Dans ce TP, j'ai utilisé Burp Suite Community Edition pour réaliser un exercice de sécurité web proposé par PortSwigger. L'objectif était d'identifier un nom d'utilisateur valide grâce à une vulnérabilité d'énumération, puis de trouver le mot de passe par force brute afin d'accéder au compte utilisateur.

1 Créer un compte sur <https://portswigger.net/>



2 Télécharger puis installer BurpSuite community edition

<https://portswigger.net/burp/releases#community>



3 Faire l'exercice "Username enumeration via different responses"

J'ai fait un essai avec des info fictif notamment « test » pour le username et password

Login

Username
test

Password
....

Log in

Sniper attack Start attack

Target <https://0a0e0099034eb4b882d6392c00750002.web-security-academy.net> Update Host header to match target

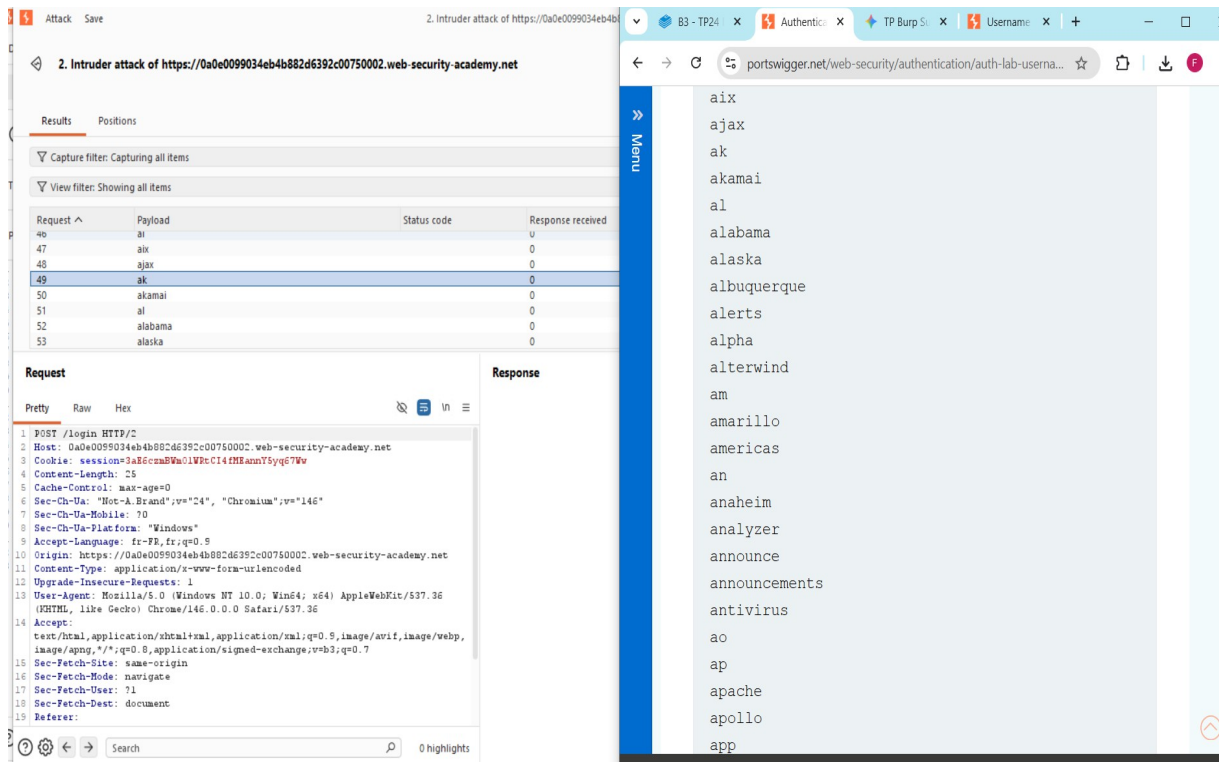
Positions Add \$ Clear \$ Auto \$

```
POST /login HTTP/2
Host: 0a0e0099034eb4b882d6392c00750002.web-security-academy.net
Cookie: session=3aE6cmBWm0lWRtCI4tMEannY5yq67Ww
Content-Length: 27
Cache-Control: max-age=0
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: fr-FR, fr;q=0.9
Origin: https://0a0e0099034eb4b882d6392c00750002.web-security-academy.net
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0a0e0099034eb4b882d6392c00750002.web-security-academy.net/login
Accept-Encoding: gzip, deflate, br
Priority: u=0, i

username=test&password=test
```

0 highlights 0 payload positions Length: 101

J'ai ensuite coller la liste des username dans l'onglet intruder j'aurai du recommencer avec les password mais je n'ai pu continuer la suite du TP comme je l'explique juste en dessous.



Lors de la phase d'énumération des utilisateurs , j'ai configuré l'outil Intruder avec la liste des 100 noms d'utilisateurs potentiels. Cependant, j'utilise Burp Suite Community Edition, la version gratuite du logiciel.

Comme on peut le voir sur mes captures d'écran, PortSwigger bride volontairement la vitesse de cette version (« throttling »). L'envoi des requêtes est donc extrêmement lent par rapport à la version Professionnelle. Le chargement de l'intégralité des noms d'utilisateurs aurait pris trop de temps pour la durée impartie du TP , je ne l'ai donc pas terminer car faute de temps mais compris le concept une fois les étapes terminer donc l'onglet LAB cela devrait afficher solved

Conclusion

Ce TP m'a permis de découvrir le fonctionnement de Burp Suite et de comprendre comment certaines différences dans les réponses d'un site web peuvent être exploitées pour trouver des identifiants valides. J'ai également appris à utiliser l'outil Intruder pour automatiser des tests de connexion et analyser les réponses du serveur.